

1. ¿Que es un playbook?

Un playbook es una guía estratégica y estructurada que describe cómo responder a un tipo específico de incidentes de seguridad.

Se enfoca en el qué se debe hacer y cuándo hacerlo

Puede incluir decisiones condicionales

Suele usarse en SOC, IR y SOAR

Puede ser semiautomatizado o automatizado

Ejemplos de playbooks:

Respuesta a un phishing

Manejos de ransomware

Detección de acceso no autorizado

Incidentes de fuga de datos

Contenido típico:

Roles y responsabilidades

Flujo de decisión

Herramientas para usar

Escalamiento

Criterios de cierre del incidente

Ejemplo práctico: si se descubre un correo sospechoso se debe analizar encabezados evaluar dichos riesgos y se decide si se aísla el usuario.

2. ¿Que es un runbook?

Un runbook es una guía técnica y detallada, paso a paso, para ejecutar una tarea específica.

Se enfoca en el cómo hacerlo

Muy operativo y técnico

Generalmente manual, aunque se puede automatizar

Pensado para técnicos, analistas o ingenieros

Ejemplos de runbooks:

Cómo aislar un endpoint en EDR

Pasos para revocar credenciales comprometidas

Procedimiento para extraer logs de un firewall

Cómo bloquear un dominio en un proxy

Contenido típico:

Prerrequisitos

Comandos específicos

Capturas o ejemplos

Validaciones

Rollback

Ejemplo práctico:

Ejecutar **isolate-device** en la consola EDR, verificar estado y documentar dicho cambio

Diferencias entre Playbook y Runbook

En el aspecto de niveles el playbook es más estratégico en cambio el runbook es más técnico

En el enfoque el playbook en que se debe hacer el runbook se define en cómo hacerlo

En el detalle el playbook se usa en incidentes de nivel medio a alto en cambio el runbook se usa en incidentes muy detallados

En el uso el playbook se usa en la respuesta a incidentes el runbook en cambio se usa para la ejecución de tareas

En la automatización el playbook se puede usar mejor con el SOAR en cambio el runbook es más bajo

En la audiencia el playbook lo utilizan los analistas SOC y líderes IR el runbook lo usan los técnicos y los admins.

1. Preparación

Antes de recibir reportes, asegúrate de que tu organización tenga: Auditoría de correo y registros habilitados. Herramientas de análisis (SIEM, correlación de logs, sandbox). Políticas y roles asignados en respuesta a incidentes. Procedimientos de reporte de correos sospechosos.

2. Análisis inicial y clasificación

Objetivo: Recopilar evidencia y entender el impacto. Recolecta datos clave:

Encabezados completos del correo.

URLs, dominios y direcciones IP.

Adjuntos y metadatos.

Indicadores de Compromiso (IoCs). Verifica interacción del usuario:

¿Se abrió el correo?

¿Se hicieron clic en links?

¿Se ejecutó algún adjunto? Determina gravedad y si el caso es aislado o parte de campaña más amplia.

3. Contención

Objetivo: Evitar mayor daño. Bloquear remitente y dominios maliciosos en tu gateway de correo. Suspende cuentas comprometidas o restablecer contraseñas si es necesario. Eliminar la amenaza de los buzones de todos los usuarios afectados. Aislar endpoints afectados en la red.

4 y 5 Erradicación y recuperación

Objetivo: Eliminar causa raíz y restaurar sistemas. Asegurar que correos maliciosos ya no están presentes en los buzones. Eliminar reglas de reenvío no autorizadas o configuraciones comprometidas. Restaurar cuentas y dispositivos a estado normal. Asegurar endpoints (antivirus/EDR actualizado).

6. lecciones aprendidas

Objetivo: Informar a las partes relevantes. Interno: informar a TI, SOC y equipos afectados. Externo: si corresponde, reportar a grupos de phishing/autoridades relevantes. A los usuarios: recordarles las mejores prácticas y alertas sobre el ataque.

